
POL-006

D&D SERVICIO INTEGRAL DE LIMPIEZA

Política de Gestión de Incidentes de Seguridad

Preparado para

D&D Servicio Integral de Limpieza

Código

POL-006

Clasificación

Interno

Elaborado Por

Francisco Noya

Versión

1.0

Fecha

03 de Agosto de 2026

1. Objetivo

Establecer los principios y lineamientos generales para la identificación, reporte, evaluación, contención y resolución de los incidentes de seguridad de la información que afecten a D&D Servicio Integral de Limpieza, minimizando su impacto y facilitando el aprendizaje organizacional a partir de ellos.

2. Alcance

La presente política aplica a:

- Todo el personal de D&D Servicio Integral de Limpieza.
- Directores y propietarios.
- Personal administrativo.
- Supervisores.
- Empleados operativos cuando utilicen activos tecnológicos.
- Contratistas y terceros con acceso a información o sistemas de la empresa.

Esta política comprende todo evento que comprometa o pueda comprometer la confidencialidad, integridad o disponibilidad de la información de la empresa, incluyendo:

- Accesos no autorizados a sistemas o información.
- Pérdida, robo o extravío de equipos o dispositivos.
- Infecciones por malware, ransomware o virus.
- Ataques de phishing o ingeniería social.
- Fallas de disponibilidad de sistemas críticos.
- Fuga o divulgación no autorizada de información.

3. Objetivos de la Política

D&D Servicio Integral de Limpieza establece como objetivos en materia de gestión de incidentes:

- Detectar y responder oportunamente a los incidentes de seguridad.
- Minimizar el impacto operativo, financiero y reputacional de los incidentes.
- Garantizar la trazabilidad y documentación de todo incidente reportado.
- Aprender de los incidentes ocurridos para fortalecer los controles existentes.
- Cumplir con la legislación y normativa aplicable en materia de protección de datos.

4. Principios de Gestión de Incidentes

Todas las decisiones relacionadas con la gestión de incidentes deberán respetar los siguientes principios:

4.1 Detección Oportuna

Todo incidente o sospecha de incidente deberá identificarse y reportarse lo antes posible.

4.2 Responsabilidad Compartida

La detección y el reporte de incidentes son responsabilidad de todos los usuarios, no únicamente del área de ciberseguridad/TI.

4.3 Contención Prioritaria

Ante un incidente, la prioridad inicial será contener su impacto y evitar su propagación.

4.4 Documentación

Todo incidente deberá quedar registrado, incluyendo las acciones tomadas para su resolución.

4.5 Mejora Continua

Cada incidente deberá analizarse para identificar oportunidades de mejora en los controles de seguridad.

5. Roles y Responsabilidades

Dirección

La Dirección deberá:

- Aprobar esta política.
- Proporcionar los recursos necesarios para la respuesta a incidentes.
- Ser informada de forma oportuna ante incidentes de impacto significativo.

Responsable de Ciberseguridad

Será responsable de:

- Mantener esta política actualizada.
- Recibir, evaluar y clasificar los incidentes reportados.
- Coordinar la contención, erradicación y recuperación ante cada incidente.
- Documentar los incidentes y las lecciones aprendidas.
- Comunicar a la Dirección los incidentes de impacto significativo.

Usuarios

Todo usuario deberá:

- Cumplir esta política.
- Reportar de inmediato cualquier incidente o sospecha de incidente de seguridad.
- Colaborar con el área de Ciberseguridad/TI durante la investigación y contención del incidente.
- No intentar resolver por su cuenta incidentes que excedan su responsabilidad o conocimiento técnico.

6. Lineamientos Generales

Todos los usuarios y sistemas deberán cumplir las siguientes normas:

Identificación de incidentes

Se considerará incidente de seguridad todo evento que comprometa o pueda comprometer la confidencialidad, integridad o disponibilidad de la información, incluyendo accesos no autorizados, pérdida de equipos, infecciones de malware o fallas de disponibilidad.

Reporte de incidentes

Todo incidente o sospecha de incidente deberá reportarse de inmediato al Responsable de Ciberseguridad, indicando qué ocurrió, cuándo se detectó y qué sistemas o información podrían verse afectados.

Clasificación de incidentes

Los incidentes deberán clasificarse según su nivel de severidad (bajo, medio, alto o crítico), considerando el impacto sobre la operación, la información y los clientes de la empresa.

Contención

Ante un incidente confirmado, deberán tomarse medidas inmediatas para contener su alcance, tales como el aislamiento de equipos afectados, la suspensión de accesos comprometidos o el bloqueo de cuentas.

Erradicación y recuperación

Una vez contenido el incidente, deberá eliminarse su causa raíz y restaurar los sistemas o la información afectada, utilizando las copias de seguridad conforme a la Política de Copias de Seguridad cuando sea necesario.

Comunicación

Los incidentes de severidad alta o crítica deberán comunicarse a la Dirección de forma inmediata. Cuando corresponda, deberá evaluarse la necesidad de notificar a clientes, autoridades u otras partes afectadas, conforme a la legislación aplicable.

Documentación y cierre

Todo incidente deberá documentarse formalmente, incluyendo su origen, impacto, acciones tomadas y fecha de resolución, hasta su cierre formal. Lecciones aprendidas Luego de cada incidente relevante, deberá realizarse un análisis posterior para identificar causas, mejoras a los controles existentes y acciones preventivas.

Lecciones aprendidas

Luego de cada incidente relevante, deberá realizarse un análisis posterior para identificar causas, mejoras a los controles existentes y acciones preventivas.

7. Cumplimiento

El incumplimiento de esta política podrá derivar en:

- Suspensión de accesos.
- Medidas disciplinarias internas.
- Acciones legales cuando corresponda.
- Revisión de permisos y responsabilidades.

8. Excepciones

Toda excepción a esta política deberá:

- Estar documentada.
- Contar con una justificación de negocio.
- Ser aprobada por la Dirección.
- Ser evaluada desde el punto de vista del riesgo.

9. Revisión de la Política

Esta política deberá revisarse:

- Como mínimo una vez al año.
- Cuando existan cambios importantes en la organización.
- Luego de incidentes relevantes de seguridad.
- Cuando cambie la legislación aplicable.

10. Documentos Relacionados

- POL-001 – Política de Seguridad de la Información
- POL-002 – Política de Gestión de Contraseñas
- POL-003 – Política de Control de Accesos
- POL-004 – Política de Uso Aceptable de Recursos Informáticos
- POL-005 – Política de Copias de Seguridad
- Manual de Gestión de Riesgos

11. Referencias

- ISO/IEC 27001:2022 – Sistemas de Gestión de Seguridad de la Información.
- ISO/IEC 27002:2022 – Controles de Seguridad de la Información (controles 5.24 a 5.28 – Gestión de incidentes de seguridad de la información).
- NIST Cybersecurity Framework (CSF) 2.0 – Funciones RESPOND (RS) y RECOVER (RC).

12. Control de Versiones

Versión	Fecha	Descripción	Autor
1.0	___ / ___ / 2026	Emisión inicial	Francisco Noya

13. Aprobación

Cargo	Nombre	Firma	Fecha
Director / Gerente General			
Responsable de Ciberseguridad	Francisco Noya		